

Princípios de Segurança da Informação

- **Confidencialidade:** Garantir que apenas utilizadores ou sistemas autorizados possam aceder a informações.
- **Integridade:** Assegurar a consistência, precisão, e confiabilidade dos dados durante todo o ciclo de vida.
- **Disponibilidade:** Garantir que utilizadores autorizados acessem a informações sem interferências.
- **Não-repúdio:** Garantir que ações possam ser atribuídas exclusivamente a uma entidade.
- **Autenticidade:** Verificar que os dados e serviços são genuínos e confiáveis.
- **CVE (Common Vulnerabilities and Exposures):** Lista de nomes padronizados para vulnerabilidades conhecidas publicamente.
- **CWE (Common Weakness Enumeration):** Lista de tipos de fraquezas em software e hardware para identificar, mitigar e prevenir problemas.

Ameaças - Modelo STRIDE

- **Spoofing:** Falsificar identidade. (Viola Autenticação)
- **Tampering:** Alterar dados. (Viola Integridade)
- **Repudiation:** Negar a autoria de uma ação. (Viola Não-repúdio)
- **Information Disclosure:** Expor dados a entidades não autorizadas. (Viola Confidencialidade)
- **Denial of Service (DoS):** Consumir recursos para negar serviços. (Viola Disponibilidade)
- **Elevation of Privilege (EoP):** Permitir ações não autorizadas. (Viola Autorização)

Ataques

- **Passivos:** Escuta sem alterar dados.
- **Ativos:** Modificação ou criação de fluxo de dados falso.

Serviços de Segurança - Processos que protegem recursos:

- Autenticação, Controlo de acesso, Confidencialidade, Integridade de dados, Não-repúdio.

Mecanismos de Segurança

- **Específicos:** Encerramento, assinatura digital, controlo de acesso, integridade de dados, troca de autenticação, entre outros.

- **Pervasivos:** Funcionalidade confiável, rotulagem de segurança, auditorias, recuperação de segurança.

Criptografia Simétrica

1. Conceitos Básicos

- **Texto simples (Plaintext):** Mensagem original
- **Algoritmo de criptografia:** Transformar o texto simples num formato ilegível.
- **Texto cifrado (Ciphertext):** Mensagem criptografada que depende do texto simples e da chave secreta.
- **Algoritmo de descriptografia:** Reverte o texto cifrado para o texto simples

2. Operação

- **Cifras em Bloco:** Processam blocos fixos de entrada (ex.: 64 ou 128 bits) e produzem saídas do mesmo tamanho.
- **Cifras em Fluxo:** Processam dados bit a bit ou caractere a caractere.
- **Substituição:** Elementos do texto simples são substituídos por elementos do texto cifrado.
- **Permutação:** Os elementos do texto simples são reorganizados sem adição ou remoção.

3. Princípios de Segurança

- **Princípio de Kerckhoff:** O sistema deve ser seguro, mesmo que tudo seja público, exceto a chave.
- **Segurança incondicional:** O texto cifrado não possui informações suficientes para recuperar o texto simples.
- **Segurança computacional:** Custo para quebrar o código supera o valor da informação e o tempo necessário para quebrar o código excede o tempo útil da informação.

4. Técnicas Clássicas

- **Cifra de César:** Substitui cada letra por outra deslocada três posições no alfabeto. Simples, mas vulnerável a ataques de força bruta.
- **Cifras Monoalfabéticas:** Permitem substituições arbitrárias.
 - Exemplo: Para o conjunto {a, b, c}, existem 6 permutações. Para o alfabeto, existem 26! ($>4 \times 10^{26}$). Mais resistentes a ataques de força bruta.

- **Cifras Polialfabéticas (Vigenère):**
 - Utiliza 26 Cifras de César com deslocamentos de 0 a 25.
 - A chave é uma frase onde cada letra define uma substituição.
- **Transposição:** O texto cifrado é gerado permutando letras do texto simples.
- **One-Time Pad: Incondicionalmente seguro** com Chave tão longa quanto a mensagem, saídas aleatórias sem relação estatística com o texto simples. Opera sobre um alfabeto binário com operações XOR. Problemas práticos: geração e distribuição de chaves.

5. Blocos Criptográficos

- **Confusão:** Cada bit do texto cifrado depende de forma complexa dos bits do texto simples.
- **Difusão:** Cada bit do texto simples afeta o maior número possível de bits no texto cifrado.

Estrutura de Cifra Feistel e Funções Hash Criptográficas

1. Estrutura de Cifra Feistel

Redes S-P:

- As **S-P Networks** são estruturas fundamentais em muitas cifras por blocos, como o AES, e têm como objetivo realizar operações de substituição e de permutação que são baseadas nas propriedades de difusão e a confusão:
- A substituição substitui cada elemento da mensagem por outro elemento de acordo com uma regra fixa ou uma tabela (chamada de S-box, ou caixa de substituição).
- A permutação rearranja os elementos da mensagem (bits ou blocos) em novas posições, seguindo uma regra fixa chamada P-box (caixa de permutação).
- Quantas mais operações (rounds) realizarmos, maior a segurança (Efeito Avalanche), e no ponto de vista do desempenho, também é melhor operar em bits.

O algoritmo de **Diffie-Hellman** é usado para criar uma chave secreta compartilhada por duas partes, mesmo em um canal inseguro.

Funcionamento:

1. Parâmetros públicos: Ambas as partes escolhem um número primo p e uma base g , conhecidos por todos.
2. Chaves privadas: Cada parte escolhe um valor secreto (A: a e B: b).
3. Chaves públicas: Cada parte calcula a sua chave pública ($A = g^a \bmod p$, $B = g^b \bmod p$) e troca com a outra.
4. Chave compartilhada: Ambas as partes usam as suas chaves privadas e as chaves públicas recebidas para calcular a chave secreta K , onde $K = g^{2ab} \bmod p$.

O que temos de garantir é:

Autenticidade -> A capacidade de identificar a identidade remetente e do destinatário da mensagem.

Confidencialidade -> A garantia de que apenas o destinatário autorizado pode ler o conteúdo da mensagem.

Integridade -> A garantia de que a mensagem não foi alterada durante a transmissão.

- 1º Criação de chaves:

A e B geram um par de chaves (pública e privada)

- 2º Troca de chaves:

A e B trocam as suas chaves públicas através de um canal seguro, como um servidor de chaves certificadas.

- 3º Criptografia da mensagem para B:

Quando A quer enviar uma mensagem para B, A utiliza a chave pública de B para criptografar a mensagem.

A gera uma assinatura digital da mensagem usando a chave privada.

A anexa a assinatura digital à mensagem encriptada.

- 4º Decifração e verificação da mensagem:

Quando B recebe a mensagem utiliza a sua chave privada para decifrar a mensagem, e utiliza a chave pública de A para verificar a assinatura digital.

2. Exemplos de Cifras

- **DES (Data Encryption Standard):**

- Cifra obsoleta, com parâmetros incompatíveis com requisitos de segurança atuais (ex.: tamanho de chave e bloco).

- **AES (Advanced Encryption Standard):**

- Baseado em campos finitos (Galois Fields).
- Opera por meio de XOR e tabelas de consulta (lookup tables).
- Não usa a estrutura Feistel.
- Todo o bloco é processado em paralelo em cada rodada, que inclui:
 - Uma permutação.
 - Três substituições.

3. Modos de Operação de Cifras em Bloco

- **Electronic Codebook (ECB)**- Cada bloco é cifrado independentemente.
- **Cipher Block Chaining (CBC)**- Cada bloco é combinado (XOR) com o bloco cifrado anterior antes de ser cifrado.
- **Cipher Feedback (CFB)**- Converte a cifra de bloco em uma cifra de fluxo, cifrando pequenos pedaços de dados.
- **Output Feedback (OFB)**- Semelhante ao CFB, mas a saída do algoritmo é usada diretamente como fluxo cifrante.
- **Counter (CTR)**- Um contador cifrado gera um fluxo pseudoaleatório, XOR com o texto claro.
- **GCM (Galois/Counter Mode)** - fornece confidencialidade e autenticação de dados de forma integrada, sem a necessidade de funções de hash externas.

True Random Number Generator (TRNG) utiliza fontes imprevisíveis para produzir números genuinamente aleatórios. Tem como principais características o baseio em componentes físicas, não determinístico e a sua imprevisibilidade.

A **cifra simétrica por fluxo** tem como função gerar uma sequência pseudoaleatória de chaves que é combinada com o texto usando operações como o Xor. Tem como principais características o modo de operação contínuo, uso de uma chave, a sua eficiência e a sua velocidade e a sua imprevisibilidade.

Assinaturas digitais: Uma assinatura digital é uma técnica criptográfica usada para garantir a integridade, autenticidade e não repúdio de informações digitais. Ela combina uma mensagem com a chave privada de um usuário, criando um valor único (hash), que é então verificado usando a chave pública correspondente para garantir que os dados não foram alterados e que são autenticados por uma entidade confiável.

Certificados digitais: Um certificado digital é usado para validar a identidade de uma entidade (pessoa, organização ou dispositivo) e para garantir a segurança em comunicações digitais. Ele associa uma chave pública a informações verificáveis, como o nome da entidade, domínio, data de validade e a assinatura de uma Autoridade Certificadora (CA). Os certificados são usados para assegurar autenticidade, confidencialidade e integridade de dados em transações seguras.

O **CRL (Certificate Revocation List)** é um arquivo que contém uma lista de certificados digitais revogados. Ele é usado para descredenciar certificados que não são mais válidos, como quando uma chave foi comprometida, o certificado expirou ou a entidade associada foi desativada. A validação de um certificado inclui verificar sua presença na CRL para garantir que ele não foi revogado.

O **OCSP (Online Certificate Status Protocol)** é um protocolo usado para verificar a validade de certificados digitais em tempo real. Ele consulta uma Autoridade de Certificação (CA) para verificar se um certificado específico foi revogado ou ainda está válido.

RSA é um algoritmo de criptografia assimétrica usado para proteger dados e garantir a segurança em comunicações digitais. Ele utiliza uma chave pública para cifrar informações e uma chave privada para descriptografar. Em relação à segurança, o RSA garante através da complexidade matemática.

AES é um algoritmo de cifragem simétrica, o que significa que utiliza a mesma chave para cifrar e descriptografar dados. Ele é amplamente utilizado para garantir a confidencialidade de informações, como em arquivos e transmissões de dados. Em relação à segurança, o AES é garantido através da difusão e confusão.

Funções de hash são algoritmos matemáticos que convertem dados de tamanhos variáveis em saídas de tamanho fixo. Elas são usadas para verificar integridade, autenticação e armazenamento seguro de informações.

Um **gerador número pseudoaleatório** (PRNG - Pseudo-Random Number Generator) é um algoritmo que cria uma sequência de números que aparentam ser aleatórios, mas são baseados em uma fórmula matemática. Este algoritmo produz a mesma sequência de números através da mesma seed. Este algoritmo é mais eficiente que o **TRNG**.

Um **gerador pseudoaleatório** (PRG- Pseudo-Random Generator) é um algoritmo que gera uma sequência de números pseudoaleatórios a partir de um pequeno valor inicial chamada seed.

One-Time Pad é um método de criptografia que oferece uma segurança perfeita. Este método consiste na geração de chaves aleatórias do tamanho do texto, em seguida a chave é combinada com a chave aleatória. Apesar deste método ser perfeito existe alguns problemas como a sua complexidade e na dificuldade na geração e distribuição das chaves do mesmo tamanho do texto.

4. Funções Hash Criptográficas

- **Definição:** Aceita um bloco de dados de tamanho variável como entrada e gera um valor hash de tamanho fixo. Usada para verificar a integridade de dados.
- **Autenticação de Mensagem:**
 - Garante que o valor hash seja transmitido de forma segura para verificar integridade.

5. Ataques e Requisitos de Segurança

- **Ataques por força bruta:**
 - **Pré-imagem e segunda pré-imagem:** Encontrar um valor que gere um hash específico.
 - **Resistência a colisões (Birthday Attack):** Encontrar dois blocos diferentes com o mesmo hash.
- **Terminologia:**

- Pré-imagem: dado que gera um hash.
- Colisão: ocorre quando $H(x) = H(y)$, com $x \neq y$.

6. Design de Funções Hash

- **Função de Compressão:** Combina duas entradas para produzir uma saída de tamanho fixo.
- **Estrutura Merkle-Damgård:**
 - Base da maioria das funções hash modernas (ex.: SHA).
 - Usa cifras de bloco encadeadas para construir funções hash.

Criptografia Assimétrica

1. Definição e Princípios

- **Criptografia Assimétrica:** Sistema que utiliza chaves diferentes, uma para criptografar ou assinar digitalmente dados e outra para descriptografar ou verificar a assinatura. Também conhecida como criptografia de chave pública.
- **Chaves Assimétricas:**
 - Duas chaves relacionadas:
 - **Chave Pública:** Pode ser compartilhada livremente.
 - **Chave Privada:** Deve ser mantida em segredo.
 - Usadas para operações complementares (ex.: criptografia e descriptografia).
- **Certificado de Chave Pública:** Documento digital emitido por uma Autoridade Certificadora (CA), associando uma chave pública a uma identidade.
- **Infraestrutura de Chave Pública (PKI):** Conjunto de políticas, processos e tecnologias para emitir, manter e revogar certificados e pares de chaves públicas e privadas.

2. Características e Limitações

- Mais seguro para troca de chaves comparado a sistemas simétricos.
- Requer protocolos de distribuição de chaves e uma autoridade central confiável.
- **Mitos:**
 - Não é imune à criptoanálise.
 - Não substituiu a criptografia simétrica.
- **Desempenho:**

- Para o mesmo nível de segurança, é muito menos eficiente que a criptografia simétrica.
- Usada em conjunto com criptografia simétrica, não como alternativa.

3. Sistemas Criptográficos de Chave Pública

- **Autenticação e Confidencialidade:**
 - Permite trocar uma chave de sessão, usada posteriormente na criptografia simétrica.
- **Ataque Man-in-the-Middle (MitM):**
 - Requer mecanismos confiáveis para associar pares de chave à identidade das entidades comunicantes.

4. Troca de Chaves de Diffie-Hellman

- **Objetivo:** Permitir que dois usuários troquem uma chave de forma segura para uso posterior na criptografia simétrica.
- Baseado na dificuldade de calcular logaritmos discretos.
- **Parâmetros:**
 - Número primo p .
 - Gerador g (raiz primitiva de p).
- **Processo:**
 - Alice escolhe x , calcula $g^x \bmod p$ e envia para Bob.
 - Bob escolhe y , calcula $g^y \bmod p$ e envia para Alice.
 - A chave partilhada é: $(g^y)^x \bmod p = (g^x)^y \bmod p$
- Vulnerável ao ataque MitM sem associação confiável entre chaves e identidades.

5. Assinatura Digital

- Contribuição principal da criptografia assimétrica: Definição de um equivalente digital ao ato de assinar documentos.
- **Propriedades:**
 - **Integridade:** Garantia de que a mensagem não foi modificada.
 - **Autenticidade:** Confirmação da identidade do remetente.
 - **Não-repúdio:** Possibilidade de provar a identidade do assinante.
- **Exemplo de Processo:**
 - Para a mensagem M :

- $H = \text{hash}(M)$
- Assinatura $S = E(PR_b, H)$
- Transmite $C = E(PU_a, M || H)$
- Alice verifica:
 - $D(PR_a, C) = M || H$
 - Verifica S: $D(PU_b, H) == \text{hash}(M)$
- Vulnerável a ataques MitM sem certificação do relacionamento entre as chaves e a identidade do assinante.

6. Certificação de Chaves

- Todos os agentes possuem a chave pública de uma Autoridade Certificadora (CA) confiável.
- A CA assina digitalmente a associação entre uma chave pública e a identidade do agente.
- Qualquer agente pode verificar a assinatura do certificado para validar a identidade.

RSA (Rivest-Shamir-Adleman)

Descrição

- RSA é um cifrador de bloco onde o texto simples e o texto cifrado são números inteiros entre 0 e $n-1$, para algum n .
- **Criptografia e Decifração:**
 - Criptografia: $C = M^e \bmod n$
 - Decifração: $M = C^d \bmod n = (M^e)^d \bmod n$
- **Chaves:**
 - Chave pública: $PU = \{e, n\}$
 - Chave privada: $PR = \{d, n\}$
- **Característica:** Uma mensagem criptografada repetidamente gera sempre o mesmo texto cifrado.
- **Mitigação:**
 - **Optimal Asymmetric Encryption Padding (OAEP):** Remove o determinismo do RSA básico, tornando-o mais seguro contra ataques de texto cifrado escolhido (CCA).

Elliptic-Curve Cryptography (ECC)

- Usada para acordos de chave, assinaturas digitais e geradores pseudoaleatórios.
- Baseada no problema do logaritmo discreto em curvas elípticas.
- **Vantagens:** Oferece segurança equivalente com chaves mais curtas. Eficiência em dispositivos com recursos limitados e baixa largura de banda.

Assinaturas Digitais: Propriedade Garantida: Integridade.

- Mecanismo que associa exclusivamente um assinante a um documento e permite validação por terceiros.
- **Usa Funções de Hash Criptográficas:**
 - Adiciona confidencialidade aos dados transmitidos.
 - Mensagem e hash criptografado com a chave privada são protegidos com uma chave simétrica.
- **Assinatura Direta:** Envolve apenas as partes comunicantes, assumindo que o verificador conhece a chave pública do assinante.

Digital Signature Standard (DSS)

- Padrão do NIST para algoritmo de assinatura digital.
- **Digital Signature Algorithm (DSA):** Usa o algoritmo de hash seguro (SHA) para gerar um resumo de mensagens de tamanho variável.
 - Assinatura gerada com: Resumo da mensagem e número aleatório k exclusivo para cada assinatura. Resulta em dois componentes: s e r .

Certificados Digitais

- Documento eletrônico que contém uma chave e informações do controlador da chave.
- Emitido e assinado digitalmente por uma Autoridade Certificadora (CA).
- Autentica a chave criptográfica embutida no certificado.
- **Formato mais utilizado:** X.509.

Infraestrutura de Chave Pública (PKI)

- Conjunto de procedimentos, tecnologias e serviços para gerenciar certificados de chave pública.
- **Componentes principais:**
 - **Autoridade Certificadora (CA):** Emite, revoga e gerencia certificados. Valida identidades e assina certificados com sua chave privada.
 - **Autoridade de Registro (RA):** Intermediário entre usuários finais e a CA, verificando identidades antes da emissão do certificado.

- **Certificado Digital:** Identifica uma chave pública, sua chave privada correspondente e o proprietário autorizado.
- **Cadeias de Confiança:** Processo recursivo que termina quando um certificado de uma CA confiável é alcançado.
- **Âncora de Confiança:** Baseia-se na confiança depositada na CA que age como raiz da cadeia.

Cifradores de Fluxo - Processam elementos de entrada continuamente (bits, bytes ou caracteres), produzindo saída elemento por elemento.

Geração de Bits Aleatórios

- **Limitações de números aleatórios verdadeiros:** Ineficiência.
- **Alternativa:** Algoritmos que geram sequências pseudorandomicamente.

Firewall: Função: Gateway de rede que restringe tráfego de dados de acordo com uma política de segurança.

- **Tipos:**
 - **Packet-Filtering Firewall:** Regras aplicadas a pacotes IP para aceitar ou descartar.
 - **Stateful Inspection Firewall:** Rastrea conexões TCP estabelecidas e permite tráfego apenas de pacotes válidos.
 - **Application-Level Gateway:** Atua como intermediário entre usuários externos e servidores, controlando tráfego e sessões de aplicativos.
 - **Circuit-Level Gateway:** Cria duas conexões TCP separadas entre usuário interno e host externo.

Segurança e Intrusões

- **Intrusão:** Ato não autorizado de burlar mecanismos de segurança.
- **Deteção de Intrusões:** Análise de informações de sistemas para identificar violações de segurança.
- **Sistema de Prevenção de Intrusões (IPS):** Detecta e tenta parar atividades intrusivas antes que atinjam o alvo.

IPS baseado em rede: Modifica ou descarta pacotes e encerra conexões TCP.

Honeypots - Sistemas enganosos usados para atrair invasores e protegê-los de sistemas críticos.